

Eura 2.0: The AI Act & Cyber Resilience Act Compliance Engine

Executive Summary

This report serves as the strategic blueprint for evolving Eura into an automated compliance platform specifically designed for the **EU AI Act (AIA)** and the **Cyber Resilience Act (CRA)**.

The regulatory landscape has shifted. The **CRA** mandates that all "products with digital elements" (software) must be secure by design, maintain a Software Bill of Materials (SBOM), and handle vulnerabilities within 24 hours. Simultaneously, the **AI Act** (Article 11, Annex IV) requires "High-Risk" AI systems to maintain exhaustive technical documentation, logging, and robustness guarantees before they can receive a CE mark.

The current Eura MVP—a manual, pull-based scanner—is insufficient for these regulations. The CRA requires **continuous** vulnerability monitoring (not just one-off scans), and the AI Act requires complex **artifact generation** (documentation) rather than simple scores.

This roadmap outlines the transition to Eura 2.0: an event-driven system that automates the **Secure Software Development Lifecycle (SSDLC)** required by the CRA and auto-generates the **Technical Documentation** required by the AI Act.

Part 1: The Eura Narrative (Re-contextualized)

We must redefine the product narrative to align with the specific anxieties driven by these two new regulations.

1.1 Technical Summary: The "Eura Loop" (Current State)

- **Current Flow:** User triggers Scan -> Backend clones Repo -> Regex checks run -> Score returned.
- **The Problem:** This is a "Snapshot" model.
 - **CRA Incompatibility:** The Cyber Resilience Act requires manufacturers to monitor vulnerabilities for the *entire lifecycle* (up to 5 years). A manual scan today does not protect against a CVE discovered tomorrow.
 - **AI Act Incompatibility:** The current output is a "list of issues." The AI Act requires a "Technical File" (Annex IV) containing architecture diagrams, data provenance, and validation metrics.¹ A simple list of bugs does not help a user pass a conformity assessment.

1.2 User Experience Summary

- **The Job to be Done:** "Help me get a CE Mark for my AI software so I can legally sell it in the EU."
 - **The Current Feeling:** "Compliance Theatre." The user sees a score, but they know they still have to manually write hundreds of pages of documentation for the notified body.
 - **The Eura 2.0 Feeling:** "Automated Conformity." Eura should feel like a *Compliance compiler*—you feed it code, and it compiles the PDF artifacts the auditor needs.
-

Part 2: Gap Analysis & Research

We compare Eura against the requirements of the new regulations and the tools that manage them.

2.1 The Cyber Resilience Act (CRA) Standard

The CRA forces developers to treat software security like product safety (similar to seatbelts in cars).

- **Requirement: The SBOM (Software Bill of Materials)**
 - **Standard:** The CRA effectively mandates SBOMs (likely in CycloneDX or SPDX format) to track supply chain risks.
 - **Eura Gap:** Eura currently scans code but does not generate a machine-readable inventory of all dependencies (an SBOM). This is a critical missing link for CRA compliance.
- **Requirement: Vulnerability Handling**
 - **Standard:** Manufacturers must report actively exploited vulnerabilities within 24 hours.
 - **Eura Gap:** Eura has no "Alerting" mechanism. If a library used in a user's repo becomes vulnerable overnight, Eura stays silent until the user logs in again.

2.2 The EU AI Act (AIA) Standard

The AI Act treats AI models as high-risk machinery.

- **Requirement: Technical Documentation (Annex IV)**
 - **Standard:** Developers must produce documentation covering "elements of the AI system," "development process," "monitoring capabilities," and "validation metrics".
 - **Eura Gap:** Eura is purely diagnostic (finding bad things). It needs to be descriptive (documenting the system structure, data sources, and model architecture) to fulfill Annex IV.
- **Requirement: Logging & Traceability (Article 12)**
 - **Standard:** High-risk AI systems must automatically record events (logs) to enable post-market monitoring.

- **Eura Gap:** Eura checks for *errors*, but it doesn't verify if the code implements the *mandatory logging infrastructure* required by Article 12.

2.3 Feature Comparison Matrix

Feature Domain	Eura (MVP)	CRA & AI Act Requirement	The Missing Link
Inventory	None	Software Bill of Materials (SBOM) (CRA)	CycloneDX Generator
Documentation	"Findings List"	Annex IV Technical File (AI Act)	AI-BOM & Doc Auto-Generation
Security	Static Scan	Secure by Design & 24h Reporting (CRA)	Continuous Vulnerability Monitoring
Traceability	None	Automatic Event Logging (AIA Art. 12)	Semgrep Rules for Logging checks
Validation	Regex	Accuracy & Robustness Metrics (AIA Art. 15)	Model Card Extraction

Part 3: Regulatory Imperatives (The "Why")

This section defines the specific technical outputs Eura must generate to satisfy the law.

3.1 Cyber Resilience Act (CRA): The Security Baseline

The CRA applies to *all* products with digital elements, not just AI.

1. SBOM Generation (CycloneDX):

- **Mandate:** Eura must parse requirements.txt, package.json, and Dockerfiles to build a complete dependency graph.
- **Tech:** Use **CycloneDX** (specifically the cyclonedx-python or cdxgen tools) to output

a standard JSON artifact.

2. Vulnerability Monitoring:

- **Mandate:** Eura must cross-reference this SBOM against CVE databases (like OSV or NVD) continuously.
- **Tech:** This requires a backend worker that runs daily, independent of user activity.

3.2 EU AI Act (AIA): The High-Risk Constraints

For AI systems, Eura must go deeper than code security.

1. The "AI-BOM" (Annex IV):

- **Mandate:** A detailed description of the model elements.¹
- **Tech:** Eura must inspect the model code (e.g., PyTorch/TensorFlow classes) to extract metadata: *Model Architecture (Layers), Hyperparameters, Training Data Sources*.

2. Quality Management System (Article 17):

- **Mandate:** Post-market monitoring and logging.
- **Tech:** Eura needs semantic rules (Semgrep) to verify that the application code includes logging statements for critical inference events (e.g., `logger.info(f"Input shape: {x.shape}")`).

Part 4: The "Perfect Eura Experience" (Eura 2.0)

In Eura 2.0, compliance is an *automated byproduct* of the development process.

4.1 The Conformity Loop

1. **Code Push:** Developer pushes code to GitHub.
2. **Eura Intercepts:**
 - **CRA Check:** Eura generates an ephemeral SBOM. It checks for known vulnerabilities (CVEs). If a "Critical" CVE exists, the PR is blocked (CRA "Secure by Design").
 - **AIA Check:** Eura scans for "Systemic Risks." It checks if the model card is updated and if logging is implemented.
3. **Artifact Generation:**
 - Eura auto-generates a **compliance/** folder in the PR containing:
 - `sbom.json` (for CRA).
 - `technical_documentation_draft.md` (for AI Act Annex IV).
4. **The Fix:**
 - If a logging requirement is missing (e.g., "No audit trail for inference"), Eura's AI Agent suggests the exact Python code to add the logger.

4.2 Architecture Updates

To support CRA/AIA, we need to add specific "Generators" to the backend.

- **SBOM Service:** A dedicated microservice (using cdxgen) that accepts a repo URL and returns a CycloneDX JSON.
 - **Doc Builder:** A module that takes the scan results and populates a "Technical Documentation Template" (based on Annex IV standards).
-

Part 5: Action Plan & Roadmap

Phase 1: The "CRA Foundation" (Security & Supply Chain)

Goal: Address the immediate security requirements of the Cyber Resilience Act.

1. **Implement SBOM Generation:** Integrate cdxgen or cyclonedx-python into the backend worker.
2. **Continuous CVE Monitoring:** Set up a daily cron job (Celery beat) that re-scans stored SBOMs against the OSV database, alerting users via email if a new vulnerability appears (addressing the 24h reporting rule).
3. **Vulnerability Blocking:** Use GitHub Checks API to fail a PR if it introduces dependencies with known critical vulnerabilities.

Phase 2: The "AI Act Documentation Engine"

Goal: Automate Annex IV Technical Documentation.

1. **Model Metadata Extraction:** Build parsers to read model_card.md (Hugging Face style) or extract metadata directly from training.py scripts.
2. **Annex IV Templating:** Create a Markdown/PDF template that maps Eura's findings to the specific sections of the AI Act (e.g., "Section 2.3: Data Governance").
3. **Logging Verification:** Write custom Semgrep rules to detect the presence/absence of logging around model inference points (Article 12 compliance).

Phase 3: The "Conformity Dashboard"

Goal: A dashboard that speaks the auditor's language.

1. **Status Page:** "CRA Status: Compliant" (All vulns patched) | "AI Act Status: 80%" (Documentation incomplete).
2. **Export:** "Download Declaration of Conformity Package" (Zips the SBOM, Tech Docs, and Scan Report into one file).

Works cited

1. Annex IV: Technical Documentation Referred to in Article 11(1) | EU Artificial Intelligence Act, accessed on January 27, 2026, <https://artificialintelligenceact.eu/annex/4/>